

TESTING PLAN

IPB Food Hub & UMKM

Platform Marketplace Digital UMKM Kampus Berbasis Web

Mata Kuliah: Keamanan Informasi (KOM1315)

Program: Ilmu Komputer, FMIPA IPB University

Semester: Genap 2025/2026

Daftar Isi

Daftar Isi.....	1
1. Pendahuluan	3
2. Ruang Lingkup Pengujian.....	3
3. Test Cases.....	4
3.1 Authentication	4
3.2 Authorization & RBAC	5
3.3 Accounting & Audit Log.....	6
3.4 Enkripsi Data (AES-256-GCM)	7
3.5 Tanda Tangan Digital (RSA-2048 PSS).....	8
3.6 Functional : Alur Pesanan.....	9
3.7 API Security	10
4. Lingkungan Pengujian.....	10
5. Kriteria Kelulusan (Pass/Fail Criteria).....	11
6. Ringkasan Hasil Pengujian Unit	11
7. Tools & Framework Pengujian	12

1. Pendahuluan

Dokumen ini mendefinisikan rencana pengujian komprehensif untuk sistem IPB Food Hub dengan fokus pada aspek keamanan informasi. Pengujian mencakup Authentication, Authorization, Accounting (AAA), enkripsi data, tanda tangan digital, serta pengujian fungsional end-to-end dari fitur utama aplikasi.

Nama Dokumen	Testing Plan : IPB Food Hub Security
Versi	1.0
Tanggal	Juni 2026
Tujuan	Memverifikasi keamanan dan fungsionalitas sistem IPB Food Hub
Ruang Lingkup	Unit test, integration test, security test, functional test
Tools	pytest, httpx, python-jose, python-cryptography, requests
Environment	Local (SQLite in-memory) dan Staging (Neon DB PostgreSQL)

2. Ruang Lingkup Pengujian

Area Pengujian	Cakupan	Prioritas
Authentication	Login, register, JWT issuance & validation, token expiry	KRITIS
Authorization / RBAC	Role guard, endpoint access per role, 403 enforcement	KRITIS
Accounting (Audit Log)	Log setiap request, completeness, query security dashboard	TINGGI
Enkripsi Data	AES-256-GCM encrypt/decrypt, field-level test, tamper detection	KRITIS
Digital Signature	RSA-2048 PSS sign/verify, payload integrity, key management	TINGGI
Functional : UMKM	CRUD UMKM, foto upload, filter kategori	SEDANG
Functional : Pesanan	Buat pesanan, update status, flow pembayaran, bukti upload	TINGGI

Functional : Rating	Beri rating, validasi nilai 1–5, balas ulasan	SEDANG
API Security	CORS headers, input validation, SQL injection probe, XSS probe	KRITIS
Performance	Response time < 500ms, concurrent user handling	RENDAH

3. Test Cases

3.1 Authentication

TC-ID	Deskripsi	Input	Expected Result	Status
AUTH-01	Register mahasiswa baru	nama, email, password valid, role=mahasiswa	201 Created; password tersimpan sebagai bcrypt hash	
AUTH-02	Register email duplikat	email yang sudah terdaftar	409 Conflict : email sudah terdaftar	
AUTH-03	Login valid	email & password benar	200 OK; response berisi access_token (JWT)	
AUTH-04	Login password salah	email valid, password salah	401 Unauthorized; event LOGIN_FAILED tercatat di log	
AUTH-05	Login user tidak ada	email tidak terdaftar	401 Unauthorized	
AUTH-06	Akses endpoint protected tanpa token	Request tanpa Authorization header	401 Unauthorized	
AUTH-07	Akses endpoint protected dengan token expired	JWT dengan exp di masa lalu	401 Unauthorized : Token tidak valid	
AUTH-08	Akses endpoint protected dengan token ditamper	JWT dengan signature diubah	401 Unauthorized	

AUTH-09	Login user suspended (status != aktif)	User dengan status='suspend'	403 Forbidden : Akun tidak aktif
AUTH-10	Update password valid	password lama benar + password baru	200 OK; password baru berhasil di-hash & disimpan

3.2 Authorization & RBAC

TC-ID	Deskripsi	Role Penguji	Endpoint	Expected
RBAC-01	Mahasiswa akses endpoint admin	mahasiswa	GET /api/admin/users	403 Forbidden; ACCESS_DENIED tercatat di log
RBAC-02	Pemilik UMKM akses endpoint admin	pemilik_umkm	GET /api/admin/users	403 Forbidden
RBAC-03	Admin akses dashboard security	admin	GET /api/security/dashboard	200 OK
RBAC-04	Mahasiswa buat pesanan	mahasiswa	POST /api/pesanan	201 Created
RBAC-05	Pemilik UMKM buat pesanan (tidak diizinkan)	pemilik_umkm	POST /api/pesanan	403 Forbidden
RBAC-06	Pemilik UMKM update status pesanan UMKM-nya	pemilik_umkm	PATCH /api/pesanan/{id}/status	200 OK
RBAC-07	Pemilik UMKM update UMKM milik orang lain	pemilik_umkm	PUT /api/umkm/{id_lain}	403 Forbidden
RBAC-08	Admin suspend user	admin	PATCH /api/admin/users/{id}/suspend	200 OK

RBAC-09	Mahasiswa akses security dashboard	mahasiswa	GET /api/security/dashboard	403 Forbidden
RBAC-10	Pemilik UMKM balas rating	pemilik_umkm	POST /api/rating/{id}/reply	200 OK

3.3 Accounting & Audit Log

TC-ID	Deskripsi	Aksi	Expected
AAA-01	Log request berhasil	GET /api/umkm oleh mahasiswa	Baris baru di audit_logs: method=GET, status=200, user_id terisi
AAA-02	Log request gagal (401)	Request tanpa token ke endpoint protected	Baris di audit_logs: status=401, user_id=NULL
AAA-03	Log request gagal (403)	Akses endpoint dengan role tidak sesuai	Baris di audit_logs: status=403; event ACCESS_DENIED di auth_activity.log
AAA-04	Log login sukses	Login dengan credential valid	Event LOGIN_SUCCESS di auth_activity.log dengan IP address
AAA-05	Log login gagal	Login dengan password salah 3 kali	3 event LOGIN_FAILED di auth_activity.log
AAA-06	Security dashboard : total request	Query /api/security/dashboard	total_requests sesuai jumlah baris di audit_logs
AAA-07	Security dashboard : top endpoint	Banyak request ke /api/menu	top_endpoints menampilkan /api/menu di posisi teratas

AAA-08	Kelengkapan log (no gaps)	Kirim 50 request berturut-turut	50 baris terbentuk di audit_logs tanpa gap
AAA-09	Durasi response dicatat	Request apapun	duration_ms > 0 dan < 30000 di setiap baris
AAA-10	Log user_agent tercatat	Request dengan User-Agent: TestClient/1.0	user_agent = 'TestClient/1.0' di baris log

3.4 Enkripsi Data (AES-256-GCM)

TC-ID	Deskripsi	Langkah Pengujian	Expected
ENC-01	Data terenkripsi di DB	Register user dengan no_telp, query langsung ke DB	Kolom no_telp di DB berisi ciphertext (bukan plaintext)
ENC-02	Dekripsi transparan via API	GET /api/auth/profile dengan JWT valid	Response JSON berisi no_telp dalam bentuk plaintext
ENC-03	IV unik per nilai	Register 2 user dengan no_telp sama; query DB	Ciphertext berbeda (karena IV random berbeda)
ENC-04	Tamper detection	Ubah 1 byte ciphertext di DB secara manual; GET profile	Raise error (GCM InvalidTag) : nilai tidak terbaca
ENC-05	Enkripsi key valid	Set ENCRYPTION_KEY = base64 of 32 random bytes	Encrypt & decrypt berhasil; encrypt(x) ≠ x
ENC-06	Key salah panjang (bukan 32 byte)	Set ENCRYPTION_KEY = base64 of 16 bytes	RuntimeError: 'ENCRYPTION_KEY harus 32 byte'
ENC-07	Key tidak diset	Unset ENCRYPTION_KEY env var	RuntimeError: 'ENCRYPTION_KEY belum diset di .env'

ENC-08	NIK terenkripsi	Register pemilik dengan NIK; query DB	Kolom nik di DB adalah ciphertext
ENC-09	Nomor rekening terenkripsi	Update profil dengan nomor_rekening; query DB	Kolom nomor_rekening di DB adalah ciphertext
ENC-10	Nomor e-wallet terenkripsi	Update profil dengan nomor_ewallet; query DB	Kolom nomor_ewallet di DB adalah ciphertext

3.5 Tanda Tangan Digital (RSA-2048 PSS)

TC-ID	Deskripsi	Langkah	Expected
SIG-01	Generate keypair	Jalankan python -m app.auth.digital_signature	File private.pem & public.pem terbuat di folder keys/
SIG-02	Sign & verify valid	sign_message(payload) → verify_signature(payload, sig)	verify_signature() → mengembalikan True
SIG-03	Verifikasi payload ditamper	sign_message(payload) → verify_signature(payload+'!', sig)	verify_signature() → mengembalikan False
SIG-04	Verifikasi signature palsu	verify_signature(payload, 'invalidsig==')	False (atau raise InvalidSignature)
SIG-05	Verifikasi dengan public key salah	Generate keypair baru; verify dengan public key yang berbeda	verify_signature() → mengembalikan False
SIG-06	Tanda tangan tersimpan di pesan	Selesaikan pesanan via API; query tabel pesanan	Kolom tanda_tangan berisi base64 string non-null

SIG-07	Private key tidak di-commit	git status / git log -- keys/	Tidak ada file .pem di git history (.gitignore aktif)
SIG-08	Determinisme payload	sign dengan JSON sort_keys=True; verifikasi ulang	Verifikasi berhasil meski key order berbeda

3.6 Functional : Alur Pesanan

TC-ID	Deskripsi	Aktor	Expected
FUNC-01	Buat pesanan	Mahasiswa	201 Created; pesanan_id terbuat; status=menunggu_pembayaran
FUNC-02	Upload bukti pembayaran	Mahasiswa	200 OK; foto_url tersimpan; status_verifikasi=pending
FUNC-03	Konfirmasi pembayaran pemilik oleh	Pemilik UMKM	200 OK; status_pembayaran=unas; status_pesanan=diproses
FUNC-04	Tolak pembayaran	Pemilik UMKM	200 OK; status_verifikasi=ditolak; catatan_verifikasi terisi
FUNC-05	Selesaikan pesanan	Pemilik UMKM	200 OK; status_pesanan=selesai; tanda_tangan terisi
FUNC-06	Beri rating setelah selesai	Mahasiswa	201 Created; nilai 1–5 valid; rating_rata_rata UMKM terupdate
FUNC-07	Rating nilai di luar range	Mahasiswa	422 Unprocessable Entity

FUNC-08	Buat pesanan ke Mahasiswa UMKM tutup	400 Bad Request : UMKM sedang tutup
---------	--------------------------------------	-------------------------------------

3.7 API Security

TC-ID	Deskripsi	Payload / Aksi	Expected
SEC-01	SQL Injection : login	email = "" OR 1=1 --"	401 Unauthorized; tidak ada data leak (ORM parameterized query)
SEC-02	SQL Injection : search UMKM	q = ""; DROP TABLE umkm; --"	200 OK dengan hasil kosong; tabel tidak terhapus
SEC-03	XSS : input nama UMKM	nama_umkm = "<script>alert(1)</script>"	Data disimpan sebagai string literal; tidak dieksekusi di browser
SEC-04	CORS : origin tidak diizinkan	Origin: https://evil.example.com	Response tanpa Access-Control-Allow-Origin header
SEC-05	CORS : origin diizinkan	Origin: https://ipb-food-hub.vercel.app	Access-Control-Allow-Origin: https://ipb-food-hub.vercel.app
SEC-06	Rate limit / brute force login	1000 request login gagal berturut-turut	Semua LOGIN_FAILED tercatat; sistem tidak crash
SEC-07	Path traversal : upload foto	filename = "../etc/passwd"	400 Bad Request atau nama file di-sanitize
SEC-08	Oversized payload	Request body > 10 MB	413 Request Entity Too Large

4. Lingkungan Pengujian

Lingkungan	Database	Auth	Keterangan
------------	----------	------	------------

Local Dev	SQLite in-memory (pytest)	JWT SECRET_KEY=test-secret	dengan	Digunakan untuk unit & integration test; fast, isolated
Staging	Neon DB PostgreSQL (branch staging)	JWT SECRET_KEY dari env var	dengan	Digunakan untuk end-to-end dan security test
Production	Neon DB PostgreSQL (main branch)	JWT SECRET_KEY production	dengan	TIDAK untuk pengujian : hanya monitoring audit log

5. Kriteria Kelulusan (Pass/Fail Criteria)

Kategori	Kriteria LULUS	Kriteria GAGAL
Security Critical	Semua TC-ID KRITIS lulus (AUTH, RBAC, ENC, SEC)	Satu pun TC-ID KRITIS gagal > release ditahan
Security High	$\geq 90\%$ TC-ID TINGGI lulus	$< 90\%$ TC-ID TINGGI lulus
Functional	$\geq 85\%$ TC-ID FUNC lulus	$< 85\%$ TC-ID FUNC lulus
Regression	Tidak ada test yang sebelumnya LULUS menjadi GAGAL	Regresi terdeteksi pada fitur apapun
Performance	Response time p95 < 500ms di staging	p95 > 1000ms

6. Ringkasan Hasil Pengujian Unit

Berdasarkan file 05_Testing/unit-test-security.log:

Modul	Total TC	LULUS	GAGAL	Coverage
Authentication (JWT + bcrypt)	10	10	0	100%
Authorization (RBAC)	10	10	0	100%
AES-256-GCM Encryption	10	10	0	100%

RSA-2048 Digital Signature	8	8	0	100%
Audit Logging (AAA)	10	10	0	100%
Functional : Pesanan	8	8	0	100%
API Security	8	8	0	100%
TOTAL	64	64	0	100%

7. Tools & Framework Pengujian

Tool	Versi	Kegunaan
pytest	≥ 8.0	Framework unit & integration test
httpx / TestClient	latest	HTTP client untuk test FastAPI endpoints
python-jose	3.x	Encode/decode JWT dalam test
cryptography	≥ 42	Test AES-256-GCM dan RSA-2048 secara langsung
SQLite (in-memory)	built-in	Database isolasi untuk test tanpa side effect
pytest-cov	latest	Code coverage reporting
requests	2.x	HTTP probe untuk security tests (CORS, injection)